

JUNIO 2026

THE BRIDGE
BOOTCAMPS



PLAYBOOK DE RESPUESTA ANTE INCIDENTES



Versión	Fecha	Estado	Clasificación
1.0	Junio 2026	Aprobado	Interno



01 Propósito y alcance

Este documento establece los procedimientos de actuación ante incidentes de seguridad en la aplicación web de turismo orientada al País Vasco. Define quién actúa, cuándo y cómo en cada tipo de incidente, con el objetivo de reducir el tiempo de respuesta, limitar el impacto y preservar evidencias para el análisis posterior.

Aplica a todos los componentes de la aplicación: módulo de autenticación, sistema de reseñas y valoraciones, geolocalización, modelo predictivo de recomendaciones e infraestructura de soporte.

Añadir introducción

02 Criterios de activación

Severidad	Tiempo de activación	Descripción
Crítico	Inmediato	Impacto directo sobre datos personales o disponibilidad total del servicio.
Alto	<30 minutos	Compromiso parcial de la aplicación o datos sensibles afectados.
Medio	< 2 horas	Comportamiento anómalo sin impacto inmediato confirmado.
Bajo	Registro y seguimiento	Actividad sospechosa sin consecuencias verificadas.



Añadir introducción

03 Roles y responsabilidades

Rol	Descripción
Responsable de incidente	Coordina la respuesta, toma decisiones de contención y es el punto de contacto con el cliente.
Analista técnico	Ejecuta las acciones técnicas: revisión de logs, aplicación de parches, contención a nivel de sistema.
Responsable de datos	Evalúa el impacto sobre datos personales y activa los procedimientos RGPD si hay fuga.
Responsable de comunicación	Gestiona la comunicación interna y, si aplica, la notificación a usuarios afectados.



04 Escenarios de incidente

4.1 ACCOUNT TAKEOVER

CRÍTICO

Acceso no autorizado a cuentas de usuarios o comercios mediante credenciales comprometidas, fuerza bruta o reutilización de contraseñas.

Indicadores de compromiso	Activos afectados
Múltiples intentos fallidos de login desde una misma IP	Módulo de autenticación
Acceso desde geolocalización inusual para el usuario	Base de datos de usuarios
Cambios de email o contraseña no solicitados	-
Actividad de cuenta en horarios atípicos	-
Alertas de credential stuffing en los logs	Tokens de sesión activos

FASES DE RESPUESTA

1	Detección y análisis Revisar logs de autenticación en busca de patrones de fuerza bruta. Confirmar si hay sesiones activas simultáneas en la cuenta afectada. Verificar si la IP de origen está en listas de reputación negativa.
---	---

**Contención****2**

Invaldar todas las sesiones activas de la cuenta afectada. Bloquear temporalmente la cuenta y las IPs de origen. Activar rate limiting estricto en el endpoint de login. No borrar logs todavía.

Erradicación**3**

Forzar reset de contraseña con verificación por email. Revisar si otras cuentas fueron afectadas por la misma fuente. Analizar el vector de entrada: ¿credenciales filtradas, fuerza bruta, phishing?

Recuperación**4**

Restaurar el acceso al usuario legítimo tras verificación de identidad. Revisar y revertir cambios no autorizados en el perfil o reseñas. Comunicar al usuario el incidente y las medidas tomadas.

Lecciones aprendidas**5**

Documentar el vector de entrada, la duración del incidente y el impacto. Evaluar implementar MFA. Actualizar reglas de detección SIEM con los IOCs identificados.

NOTIFICACIONES

A quién	Cuándo	Cómo
Usuario afectado	Inmediato	Email + notificación in-app
Responsable del proyecto	< 1 hora	Mensaje directo con resumen del incidente
AEPD (si hay fuga de datos)	< 72 horas	Notificación formal según RGPD art. 33



4.2 FAKE REVIEWS MASIVAS **ALTO**

Publicación automatizada o coordinada de reseñas falsas para manipular las valoraciones de establecimientos, ya sea para inflar o hundir la reputación de un negocio.

Indicadores de compromiso	Activos afectados
Volumen inusual de reseñas en un periodo corto	Sistema de reseñas y valoraciones
Múltiples reseñas desde rangos de IP similares	Modelo predictivo de recomendaciones
Cuentas recién creadas con actividad concentrada	Reputación de establecimientos
Patrones de texto repetitivos o muy similares	Integridad del contenido de la plataforma
Valoraciones extremas (solo 1 o solo 5 estrellas)	Reputación de establecimientos

FASES DE RESPUESTA

1	Detección y análisis Identificar el patrón: ¿automatizado o coordinado manualmente? Agrupar las reseñas sospechosas por IP, dispositivo, cuenta y timestamp. Evaluar el impacto en la puntuación del establecimiento afectado.
2	Contención Ocultar las reseñas sospechosas de la vista pública sin eliminarlas (preservar evidencia). Bloquear las cuentas y IPs involucradas. Activar CAPTCHA o validación adicional en el formulario de reseñas.



3

Erradicación

Eliminar definitivamente las reseñas falsas tras confirmarlas. Recalcular la puntuación del establecimiento. Banear las cuentas implicadas y sus variantes identificadas.

4

Recuperación

Notificar al establecimiento afectado con la situación resuelta. Verificar que el modelo predictivo no haya incorporado las valoraciones falsas. Restaurar la puntuación correcta.

5

Lecciones aprendidas

Evaluar la implantación de validación por email antes de publicar reseñas. Considerar un sistema de moderación automática con umbral de alerta. Actualizar los límites de rate limiting en el endpoint de reseñas.

NOTIFICACIONES

A quién	Cuándo	Cómo
Establecimiento afectado	< 2 horas	Email con explicación y estado de la situación
Responsable del proyecto	< 4 horas	Informe de incidente



4.3 FUGA DE DATOS DE USUARIOS

CRÍTICO

Exposición no autorizada de datos personales almacenados en la plataforma, incluyendo emails, contraseñas hasheadas, historiales de geolocalización o preferencias de usuario.

Indicadores de compromiso	Activos afectados
Queries inusuales o masivas a la base de datos	-
Exportaciones de datos fuera del horario habitual	-
Aparición de datos en foros o servicios de terceros	-
Alertas de exfiltración en el SIEM	-
Acceso de cuentas con privilegios desde IPs externas	-

FASES DE RESPUESTA

1	Detección y análisis Determinar qué datos se han expuesto y su volumen. Identificar el vector: ¿inyección SQL, acceso con credenciales robadas, misconfiguration? Evaluar si los datos incluyen categorías especiales bajo RGPD.
2	Contención Aislar el sistema afectado si es necesario. Revocar credenciales de acceso comprometidas. Activar modo de solo lectura en la base de datos si la situación lo requiere. Preservar todos los logs.



3

Erradicación

Cerrar el vector de entrada identificado. Aplicar parche o corrección de configuración. Auditar todos los accesos desde la fecha estimada del inicio del incidente.

4

Recuperación

Forzar cambio de contraseña a todos los usuarios afectados. Restaurar desde backup limpio si hubo modificación de datos. Verificar integridad del sistema antes de reactivar.

5

Lecciones aprendidas

Revisar el modelo de cifrado de datos en reposo. Evaluar la segmentación de la base de datos. Actualizar el registro de actividades de tratamiento con el incidente.

NOTIFICACIONES

A quién	Cuándo	Cómo
AEPD	< 72 horas	Notificación obligatoria si hay riesgo para los afectados (art. 33 RGPD)
Usuarios afectados	Sin dilación indebida	Email con descripción clara del incidente y medidas tomadas (art. 34 RGPD)
Responsable del proyecto	Inmediato	Llamada + informe escrito



4.4 INYECCIÓN SQL O XSS DETECTADO **ALTO**

Intento o ejecución exitosa de inyección de código malicioso a través de los campos de entrada de la aplicación, como reseñas, búsquedas o formularios de registro.

Indicadores de compromiso	Activos afectados
Alertas del WAF sobre patrones de inyección	-
Queries malformadas en los logs de base de datos	-
Scripts inesperados en el contenido de reseñas	-
Errores de base de datos expuestos en respuestas HTTP	-
Comportamiento inusual en el navegador de usuarios	-

FASES DE RESPUESTA

1	Detección y análisis Determinar si el ataque fue un intento o tuvo éxito. Identificar el campo afectado y el payload utilizado. Revisar si hay datos extraídos o código inyectado persistente en la base de datos.
2	Contención Deshabilitar temporalmente el campo o endpoint afectado. Bloquear la IP de origen. Si hay XSS persistente, desactivar la visualización del contenido afectado hasta su saneamiento.



3

Erradicación

Limpiar el contenido malicioso de la base de datos. Implementar o reforzar la sanitización del input en el campo afectado. Añadir reglas específicas al WAF para el payload detectado.

4

Recuperación

Reactivar el endpoint tras verificar que la corrección es efectiva. Realizar prueba de regresión sobre el campo afectado. Comunicar a full stack los cambios necesarios en el código.

5

Lecciones aprendidas

Auditar todos los campos de entrada de la aplicación con el mismo criterio. Añadir el caso al informe OWASP del proyecto. Actualizar el checklist de SonarQube con la vulnerabilidad detectada.

NOTIFICACIONES

A quién	Cuándo	Cómo
Equipo de desarrollo	Inmediato	Descripción técnica del vector y corrección necesaria
Responsable del proyecto	< 2 horas	Informe de incidente con impacto estimado



4.5 DENEGACIÓN DE SERVICIO **ALTO**

Sobrecarga de la aplicación mediante tráfico masivo o peticiones maliciosas que impiden el acceso normal a usuarios legítimos.

Indicadores de compromiso	Activos afectados
Pico anómalo de tráfico en métricas del servidor	-
Tiempos de respuesta elevados o timeouts	-
Múltiples peticiones idénticas desde pocas IPs	-
Saturación de CPU o memoria en el servidor	-
Alertas de disponibilidad del sistema de monitorización	-

FASES DE RESPUESTA

1	Detección y análisis Distinguir entre DoS (una fuente) y DDoS (múltiples fuentes). Identificar el endpoint o recurso objetivo. Estimar el volumen de tráfico legítimo vs malicioso.
2	Contención Bloquear las IPs de origen identificadas a nivel de firewall. Activar rate limiting agresivo en todos los endpoints. Evaluar activar modo de mantenimiento si el servicio está degradado severamente.

3	Erradicación Limpiar las reglas temporales de bloqueo una vez estabilizado el tráfico. Verificar que no hubo actividad maliciosa adicional aprovechando el incidente como distracción.
4	Recuperación Restaurar el servicio normal de forma gradual. Verificar integridad del sistema. Comunicar a usuarios la resolución del incidente si la caída fue visible.
5	Lecciones aprendidas Revisar la propuesta de infraestructura para incluir protección anti-DDoS. Actualizar el BCP/DRP con el RTO real medido durante el incidente. Evaluar la implementación de un CDN con capacidades de mitigación.

NOTIFICACIONES

A quién	Cuándo	Cómo
Usuarios (si caída visible)	< 30 minutos	Banner en la app o página de estado
Responsable del proyecto	Inmediato	Alerta con duración estimada y estado actual

